The Common — Moderation, Safeguarding & Audit Logging: Developer Spec

Oct 12, 2026 · @David Morris

1. Overview and scope

Every piece of user-generated or partner-generated content on The Common is held for human approval before it goes live, every decision is logged, and anything harmful or illegal is routed to a safeguarding officer who decides on external referral.

In scope

- Approval workflows for: marketplace posts and replies, business profiles and listings, events, journalist articles, council news, alerts and service edits, and user profile creation or changes.
- Edit workflows (an edit is a new version that needs approval; the live version stays up until then).
- Moderation queues, decline notices, appeals and super user oversight.
- Safeguarding case management and evidence preservation.
- Audit logging, search by user ID and date, and CSV export.
- Endpoints, data models, notifications, security and UK compliance requirements.

Out of scope (covered elsewhere)

- Authentication, registration and general dashboards (see the User Journey, Roles and Permissions spec v1.0).
- Payments, subscriptions and ticketing.
- News scraping and RSS ingestion, except that ingested items enter the same approval queue.

Design principles

1. Human decides. Automated checks only flag and prioritise; they never approve or decline on their own.
2. Nothing goes live unapproved. Default state of all new content is not visible to the public.
3. Four-eyes. No one approves or declines their own content.
4. Append-only history. Decisions, versions and audit entries are never edited or deleted.
5. Least privilege. Safeguarding material is visible only to the safeguarding officer and super user.

6. Server-side enforcement. Every permission is checked in the API, never only in the UI.

2. Roles and permissions

Nine roles; the super user can do everything the others can, and every override is logged with a reason. Roles are checked on the server for each request.

Role	Creates content	Reviews content	Sees safeguarding cases	Sees audit log
General public	Marketplace posts, replies, reports, profile	No	No	Own actions only (optional)
Business	Business profile, listings, events, replies	No	No	Own actions only
Event host	Events, replies to event messages	No	No	Own actions only
Journalist	News articles	No	No	Own actions only
Council partner	Council news, alerts, service edits	No	No	Own actions only
Content monitor	No	Standard queue; can decline, approve, escalate	Flag only (cannot open case)	No
Admin	Limited (own admin posts go to a different reviewer)	All queues except safeguarding; appeals triage	Flag only	Yes: search and export
Safeguarding officer	No	Safeguarding queue; can hide, remove, suspend	Yes: full access	Yes: safeguarding events
Super user (founder)	Yes	All queues, plus override of any decision	Yes	Yes: full, plus export

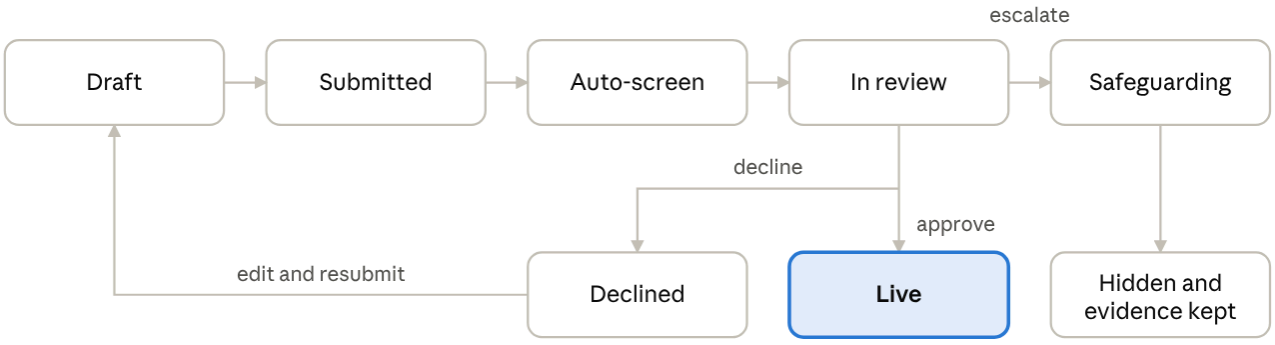
Rules

- Journalist articles, council news and council alerts require admin or super user approval; a content monitor alone cannot approve them.
- Council alerts may be given an urgent priority with a shorter review target (see section 4).
- A reviewer cannot act on content they authored, or on content from an account they manage.
- Only the super user can change roles, and each change is audit logged.
- Moderators see a flagged item's content but not the reporter's identity unless needed for the case.

3. Submission lifecycle

Every content type (post, business, event, article, council item, profile) follows the same states, so one workflow engine and one set of queues serve them all.

Nothing goes live until a human approves it



A live item stays live while its edit (version N+1) waits in review.
Serious auto-screen flags skip standard review and go straight to safeguarding.

submission lifecycle · 8 states

A decline sends the creator back to editing, and a live item stays live while its edit is reviewed.

Transitions

From	To	Trigger	Who
Draft	Submitted	Creator submits	Owner
Submitted	Auto-screen	Automatic on submit	System
Auto-screen	In review	No serious flags	System

From	To	Trigger	Who
Auto-screen	Safeguarding	Serious flag	System
In review	Live	Approve	Reviewer allowed for that content type (section 2)
In review	Declined	Decline with reason code and explanation	Reviewer
In review	Safeguarding	Escalate	Reviewer
Declined	Draft	Creator edits and resubmits	Owner
Declined	In review	Appeal upheld	Super user or delegate
Live	Submitted (version N+1)	Creator edits	Owner
Live	Expired or removed	Expiry date reached, or a safeguarding or admin action	System, safeguarding officer, admin
Safeguarding	Hidden, evidence kept	Case opened	System

4. Moderation workflow

Every submission passes automated screening, then a human reviewer, and the creator is always told the outcome.

Step by step

1. **Submit.** The creator submits; the system stores a version, sets status to Submitted and writes an audit entry.
2. **Auto-screen.** Text and images are checked for hate speech, threats, abuse, child safety indicators, illegal goods or services, scams and personal data. The result is a risk score and a list of flags, stored with the submission.
3. **Route.** No flags: standard queue. Any serious flag: safeguarding queue and the item is hidden from standard reviewers. Council alerts: urgent queue.
4. **Review.** A reviewer opens the item, sees the content, flags and history, and approves, declines or escalates. Claiming an item locks it for 15 minutes to avoid double review.
5. **Approve.** The item goes live (or the new version replaces the live one), the creator is notified, and the decision is logged.

6. **Decline.** The reviewer must pick a reason code and write an explanation. The creator is notified with both, and may edit and resubmit or appeal.
7. **Escalate.** The reviewer sends it to safeguarding with a note; it moves to the safeguarding queue (section 5).

Edits

- An edit creates version N+1 in status Submitted; the live version N stays visible.
- Approval of N+1 swaps it in. Decline leaves N live and notifies the creator.
- Changes to material fields (business name, address, category, event date, venue, price) always need approval. Typos and whitespace changes can be auto-approved if you choose, but still logged.

Review targets (configurable)

Queue	Target	Escalation if missed
Standard	24 hours	Alert admin
Journalist and council news	24 hours	Alert admin and super user
Council alerts (urgent)	1 hour	Alert admin and super user
Safeguarding flags	2 hours	Alert safeguarding officer and super user
Appeals	3 working days	Alert super user

Decline reason codes

Code	Meaning
D01	Harmful, abusive or disrespectful
D02	Discriminatory or hateful (also triggers escalation)
D03	Illegal goods, services or activity (also triggers escalation)
D04	Misleading, scam or fraudulent
D05	Personal data or privacy breach
D06	Copyright or ownership issue
D07	Incomplete or inaccurate information
D08	Off-topic or against marketplace rules
D09	Low quality (images, text)

Code	Meaning
D10	Other (explanation required)

Decline notices for D02 and D03 should be worded neutrally, and the safeguarding officer decides whether any further action is communicated to the user.

Appeals and overrides

- A creator can appeal one decline per version within 14 days; the super user (or a delegated senior admin) reviews it.
- The super user can override any decision, including approvals, but must record a reason. Overrides are flagged in the audit log and shown in the super user dashboard.

5. Safeguarding workflow

Flagged content is hidden at once, preserved as evidence, and assessed by the safeguarding officer, who alone decides whether to refer it to the police or another authority. The system never reports automatically.

Sources of a flag

- Auto-screen result above a set threshold.
- A reviewer escalation (decline codes D02, D03, or manual).
- A user report (report button on every post, listing, event, article and message).
- The incident reporting feature under community services (photo and video evidence), which creates a case directly.

Case handling

1. **Create case.** A case is opened with a reference number, the content ID, its versions, author ID, the reporter (if any), timestamps and flags. Status: Open.
2. **Hide and preserve.** The content is removed from public view and from standard reviewer queues. A read-only evidence snapshot is stored: text, media files, metadata, IP address and device information, and hashes of all media.
3. **Triage.** The officer assigns a severity (Low, Medium, High, Critical) and an outcome: no action, remove and warn, suspend the account, ban, or refer externally.
4. **Referral.** For an external referral the officer records the agency, date, reference number given, and the person who made the report. The officer chooses the route, for example police via 101 (or 999 if someone is at immediate risk), the Internet Watch Foundation for child sexual abuse material, or the borough's children's or adult safeguarding team. The officer reports outside the app; the app only records it.

5. **Preserve and share.** The case file can be exported as a locked PDF or ZIP for an authority; every export is logged.
6. **Close.** The case is closed with a summary. Closed cases are retained according to the retention schedule in section 10.

Rules

- Hidden content and evidence are never deleted by moderators or admins, only by a retention job approved by the super user.
- Case files are visible only to the safeguarding officer and super user. Every view of a case is logged.
- The system must not tip off a user about a referral if it could prejudice an investigation. The officer chooses what, if anything, to tell them.
- Critical flags (for example child safety, credible threats) alert the officer immediately by email and push notification, with a phone escalation path if unacknowledged.
- Provide a safeguarding officer deputy so cover exists when the officer is absent.

6. Audit logging

The audit log is a write-once record of every action by every user and every system event that changes content, access or decisions. It can be searched by user ID and date and exported to CSV.

What is logged

- Authentication: login, logout, failed login, password or MFA change.
- Content: create, edit, submit, withdraw, expire, remove.
- Moderation: claim, approve, decline (with reason code), escalate, appeal, override.
- Safeguarding: flag, case opened, case viewed, status or severity change, referral recorded, evidence exported.
- Admin: role change, user suspend or reinstate, settings change, queue reassignment.
- Data: audit search, audit export, any export of personal data.
- System: auto-screen result, notification sent, scheduled retention job.

Schema (`audit_log`)

Field	Type	Notes
id	UUID	Primary key
seq	bigint	Monotonic sequence for ordering
timestamp_utc	timestamptz	Server time, not client

Field	Type	Notes
actor_user_id	UUID	Null for system events
actor_role	text	Role at the time of the action
action	text	Enumerated, for example CONTENT_APPROVED
entity_type	text	Submission, business, event, case, user, and so on
entity_id	UUID	Target of the action
version	int	Content version where relevant
before / after	JSONB	Diff of changed fields; no secrets
reason	text	Decline reason code or override reason
ip_address, user_agent	text	Retained under the retention schedule
outcome	text	Success or failure
prev_hash, hash	text	Hash chain for tamper detection

Integrity

- The application database role has INSERT and SELECT only on this table; no UPDATE or DELETE.
- Each row stores a hash of its content plus the previous row's hash. A nightly job verifies the chain and alerts the super user on a break.
- Backups of the log are held separately.

Search

- Filters: user ID (actor or target), date range, role, action, entity type and ID, outcome. Free-text search covers the reason field.
- Indexes on (actor_user_id, timestamp_utc), (entity_type, entity_id) and (timestamp_utc).
- Results are paginated (default 50, maximum 200) and sorted newest first.

Export

- Admin and super user can export the filtered results as CSV (UTF-8, opens in Excel). Safeguarding events are excluded unless the requester is the safeguarding officer or super user.
- Large exports run as a background job and are made available by a signed link that expires after 24 hours.
- Each export is itself logged with who, when and which filters.

- Guard against CSV injection: prefix cell values beginning with =, +, - or @ with an apostrophe.
- Suggested columns: timestamp_utc, actor_user_id, actor_role, action, entity_type, entity_id, version, reason, outcome, ip_address.

7. Data models

Suggested relational tables (PostgreSQL assumed). Field lists are the minimum; the developer can add indexes and constraints.

Table	Key fields	Purpose
submissions	id, type, owner_user_id, status, current_live_version_id, priority, created_at, expires_at	One row per piece of content (post, business, event, article, council item, profile)
submission_versions	id, submission_id, version_no, payload (JSONB), status, submitted_at, auto_screen_score, auto_screen_flags	Every draft and edit; immutable once submitted
moderation_decisions	id, version_id, reviewer_id, decision (approve, decline, escalate, override), reason_code, explanation, decided_at	Append-only record of each decision
moderation_claims	id, version_id, reviewer_id, claimed_at, expires_at	Prevents double review
appeals	id, decision_id, creator_id, message, status, resolved_by, resolved_at, outcome	Creator appeals
reports	id, reporter_id, entity_type, entity_id, category, details, status, created_at	User reports of content
safeguarding_cases	id, ref_no, entity_type, entity_id, severity, status, assigned_officer_id, outcome, opened_at, closed_at	Case file header
case_evidence	id, case_id, snapshot (JSONB), media_refs, media_hashes, captured_at	Read-only evidence

Table	Key fields	Purpose
case_referrals	id, case_id, agency, referred_at, referred_by, external_ref, notes	External referral record
case_notes	id, case_id, author_id, note, created_at	Officer notes, append-only
notifications	id, user_id, type, entity_id, channel, sent_at, read_at	Creator and reviewer notices
audit_log	See section 6	Tamper-evident action history
retention_rules	id, data_class, retention_period, legal_basis	Retention schedule driven by policy
export_jobs	id, requester_id, type, filters, status, file_ref, expires_at	Audit and case exports

Notes

- Public pages read only from the approved live version, never from drafts.
- Soft delete everywhere; hard deletion only through the approved retention job.
- Store media in private object storage; serve moderation previews through signed, short-lived URLs.
- Encrypt case evidence and safeguarding notes at rest, with a separate key from the main database.

8. API endpoints

REST, JSON, versioned under `/api/v1`. All endpoints require authentication, enforce role checks server-side, write an audit entry for every state change, and return `403` on role failure and `409` on a stale version or claim.

Submissions (creators)

Method and path	Roles	Purpose
POST /submissions	Public, business, host, journalist, council	Create a draft
PATCH /submissions/{id}	Owner	Edit a draft or create a new version of live content

Method and path	Roles	Purpose
POST /submissions/{id}/submit	Owner	Send the current version for review
POST /submissions/{id}/withdraw	Owner	Withdraw a pending version
GET /submissions/mine	Owner	List own items and statuses
GET /submissions/{id}/decision	Owner	See decline reason and explanation
POST /submissions/{id}/appeal	Owner	Appeal a decline

Moderation

Method and path	Roles	Purpose
GET /moderation/queue	Monitor, admin, super user	Search and filter by type, status, priority, date, user ID, keyword
GET /moderation/items/{versionId}	Monitor, admin, super user	Item, flags, history, previous version diff
POST /moderation/items/{versionId}/claim	Monitor, admin, super user	Lock for review
POST /moderation/items/{versionId}/approve	Monitor, admin, super user	Approve and publish
POST /moderation/items/{versionId}/decline	Monitor, admin, super user	Body: reason_code, explanation (required)
POST /moderation/items/{versionId}/escalate	Monitor, admin, super user	Send to safeguarding with a note
GET /moderation/appeals	Admin, super user	List appeals
POST /moderation/appeals/{id}/resolve	Super user (or delegate)	Uphold or reject
POST /superuser/override/{decisionId}	Super user	Override with a reason
GET /superuser/overview	Super user	Counts and recent decisions across all queues

Reports and safeguarding

Method and path	Roles	Purpose
POST /reports	Any signed-in user	Report content or a user
GET /safeguarding/cases	Safeguarding officer, super user	List and search cases
GET /safeguarding/cases/{id}	Safeguarding officer, super user	Case, evidence, notes (logged as a view)
PATCH /safeguarding/cases/{id}	Safeguarding officer	Severity, status, assignment

Method and path	Roles	Purpose
POST /safeguarding/cases/{id}/notes	Safeguarding officer	Add a note
POST /safeguarding/cases/{id}/referrals	Safeguarding officer	Record an external referral
POST /safeguarding/cases/{id}/action	Safeguarding officer	Remove content, warn, suspend or ban a user
POST /safeguarding/cases/{id}/export	Safeguarding officer, super user	Create evidence pack for authorities

Audit

Method and path	Roles	Purpose
GET /audit	Admin, super user, officer (safeguarding events)	Params: userId, from, to, role, action, entityType, entityId, q, page
POST /audit/export	Admin, super user	Body: same filters; returns a jobId
GET /audit/export/{jobId}	Requester	Status and signed CSV link

Notifications

Method and path	Roles	Purpose
GET /notifications	Any	Own notices
POST /notifications/{id}/read	Any	Mark read

Conventions

- Decline request body: `{"reason_code": "D04", "explanation": "The price shown does not match the listing."}`
- Pagination: `page` and `pageSize`; responses include `total`.
- Idempotency: state-changing POSTs accept an `Idempotency-Key` header.
- Rate limits: stricter limits on `POST /reports` and `POST /submissions` to limit abuse.

9. Notifications

Creators are told every outcome; reviewers are alerted to new work and missed targets. All notifications are in-app, with email and push as configurable channels, and each send is logged.

Trigger	Recipient	Content
Submission received	Creator	Confirmation and expected review time
Approved	Creator	Link to the live item
Declined	Creator	Reason code, written explanation, how to edit and resubmit, how to appeal
Edit approved or declined	Creator	As above, noting the previous version remains live if declined
Appeal outcome	Creator	Decision and explanation
Item in a queue	Reviewers	Count and priority (batched)
Review target missed	Admin, super user	Item and age
Critical safeguarding flag	Safeguarding officer, deputy, super user	Immediate alert with case reference
Content removed or account suspended	Affected user	Neutral wording; no detail that could prejudice an investigation
Audit export ready	Requester	Signed link and expiry

Templates

- Use plain, respectful wording, tied to the community guidelines.
- A decline notice must always say what was wrong and what the creator can do next.
- Do not reveal reporter identities.

10. Security, privacy and UK compliance

This section lists requirements for the build. It is not legal advice: have a solicitor with online safety and data protection experience confirm the legal wording, retention periods and thresholds before launch.

Online safety (Online Safety Act 2023, regulated by Ofcom)

- Carry out and document an illegal content risk assessment for the platform, and refresh it when features change.
- Provide easy-to-find reporting and complaints tools (the report button and appeals in this spec).
- Remove or hide illegal content swiftly once identified, and keep records of the measures taken.
- Have clear terms of service and community guidelines that state what is not allowed and how moderation works.
- Assess whether children are likely to use the service; if so, add age assurance and child safety measures, and consider the ICO's Children's Code.
- Consider whether any services you add later (for example, direct messaging) bring extra duties.

Data protection (UK GDPR and Data Protection Act 2018)

- Register with the ICO and pay the data protection fee.
- Record the lawful basis for each data class (for example, contract for business accounts, legal obligation or legitimate interests for moderation and safeguarding).
- Complete a Data Protection Impact Assessment before launch; moderation, safeguarding and incident reporting are high-risk processing.
- Safeguarding cases may include criminal offence data and special category data, which need an extra condition under the Act and an appropriate policy document.
- Support subject access, rectification and erasure requests, with documented exemptions for evidence held for a safeguarding or legal purpose.
- Agree data-sharing terms with Lambeth Council and other council partners, and with any authority that receives case files.
- Use processors (hosting, AI screening, email) only under written contracts; check where data is processed.

Retention (to be confirmed with legal)

Data	Suggested starting point
Audit log	Minimum of 6 years, with IP addresses pseudonymised after a shorter period
Approved content	Life of the content plus a set period after removal or expiry
Declined content	12 months
Safeguarding cases without referral	Set by policy, for example 6 years

Data	Suggested starting point
Cases referred to authorities	Until the authority confirms it is no longer needed, then by policy

Retention jobs must be approved by the super user and logged. Legal holds suspend deletion.

Security controls

- Multi-factor authentication for all staff roles (monitor, admin, safeguarding officer, super user).
- Role-based access control enforced in the API; separate staff roles from creator roles on one account.
- Encryption in transit (TLS) and at rest; separate keys for safeguarding evidence.
- Short-lived signed URLs for media; virus and content scanning of uploads.
- Session timeouts and IP or device alerts for staff accounts.
- Regular penetration testing and dependency scanning; secrets held in a vault.
- Logging of every access to personal or safeguarding data.

People and process

- Name a safeguarding lead and a deputy; give both training for children's and adult safeguarding (the borough's safeguarding partnership can advise).
- Moderator training, written moderation guidelines and a calibration process (sample reviewed items checked for consistency).
- Moderator welfare: rotation, limits on exposure to harmful content, and access to support.
- A published complaints and appeals process, and an incident response plan for data breaches (72-hour ICO reporting).

11. Non-functional requirements and acceptance criteria

Non-functional

- Queue and audit searches return in under 2 seconds for 1 million audit rows.
- Audit export of 100,000 rows completes in under 5 minutes as a background job.
- Approved content appears publicly within 10 seconds of approval.
- 99.5% availability for the moderation console; safeguarding alerts must be delivered within 1 minute.
- WCAG 2.2 AA accessibility for all creator and reviewer screens.

- Daily encrypted backups; restore tested quarterly.

Acceptance criteria

- [ ] New content from any creator role is not visible to the public until approved.
- [ ] A reviewer cannot approve or decline their own content, or content from an account they manage.
- [ ] A decline cannot be saved without a reason code and an explanation, and the creator receives both.
- [ ] An edit to live content keeps the old version live until the new version is approved; declining it leaves the old version live.
- [ ] Journalist and council items cannot be approved by a content monitor alone.
- [ ] Content flagged as serious is hidden from standard reviewers and appears only in the safeguarding queue.
- [ ] Evidence is preserved on escalation and cannot be edited or deleted by moderators or admins.
- [ ] Only the safeguarding officer and super user can open a case, and each view is logged.
- [ ] A referral to an external authority can be recorded with agency, date and reference; nothing is sent automatically.
- [ ] Every create, edit, submit, approve, decline, escalate, override and role change creates an audit entry.
- [ ] Audit entries cannot be updated or deleted through the application; a broken hash chain raises an alert.
- [ ] The audit log can be searched by user ID and by date range, and the results exported to a CSV that opens correctly in Excel.
- [ ] Cells starting with =, +, - or @ are neutralised in the CSV export.
- [ ] A super user override requires a reason and appears flagged in the log and on the super user dashboard.
- [ ] Missed review targets raise alerts to the right roles.
- [ ] Each API endpoint returns 403 to roles not listed against it.

12. Open questions

Decisions needed before build starts.

- [ ] Who is the named safeguarding officer and deputy for the Lambeth pilot, and what is the out-of-hours cover?
- [ ] Who may approve each content type (for example, can a content monitor approve business listings, or only admin)?

- [ ] Should minor edits (typos) be auto-approved, or should every edit be reviewed?
- [ ] Review targets: are the suggested times (24 hours standard, 1 hour council alerts, 2 hours safeguarding) achievable with the planned team?
- [ ] Which auto-screening provider will be used, and where is its data processed?
- [ ] Decided: the app is 18 and over only. Ask a solicitor to confirm that the age declaration in section 13 is enough for the Online Safety Act children's access assessment.
- [ ] Is direct messaging between users planned? If so, how will private messages be moderated and reported?
- [ ] Retention periods for each data class, confirmed by a solicitor.
- [ ] Data-sharing agreement with Lambeth Council and the route for referrals to local police.
- [ ] Does the super user want to approve every item, or review decisions after the fact through the oversight dashboard?
- [ ] Should reviewers be able to see the creator's full profile history when reviewing?

13. Age declaration and 18+ policy

Policy. The Common is for people aged 18 and over. Accounts, posting, ticket purchases and marketplace purchases are adult-only. Adults may attend family events and may buy tickets for children, but a child never holds an account, and no child's name, age or other details are collected (ticket quantity only).

Legal note. A self-declaration reduces risk but does not remove the platform's duties under the Online Safety Act 2023 (the children's access assessment) or UK GDPR. Have a solicitor confirm the wording and whether stronger age checks are needed, and cover this in the DPIA. Avoid marketing the app to under-18s.

Declaration flow

1. **Sign-up:** the person enters a date of birth and ticks the declaration. The server works out their age, stores only the result, and discards the date of birth.
2. **Under 18:** the account is not created. Show the neutral message below. Nothing the person typed is saved. The device or session is blocked from retrying for 24 hours.
3. **Existing accounts:** on first sign-in after release, the declaration screen appears before anything else, and again whenever the Terms version changes.
4. **Checkout (tickets and marketplace):** the buyer ticks the purchase confirmation. The order cannot complete without it.
5. **All roles:** business owners, event hosts, journalists, council partners and staff all make the same declaration.

6. **Reports:** every post, profile and listing has the report reason "This account may belong to a child", routed to the admin queue (or safeguarding if a child may be at risk).
7. **Suspected under 18:** an admin flags the account, which suspends it at once. The user may confirm their age through an approved route. If not confirmed, the super user removes the account and its personal data. If a child may be at risk, the case goes to safeguarding.

Wording

- **Declaration (sign-up and existing accounts):** "The Common is for people aged 18 and over. Please enter your date of birth." Then the checkbox: "I confirm that I am 18 or over, and that I have read and agree to the Terms of Use and Privacy Notice." Then the note: "Parents and guardians: The Common is not for under-18s. Adults can attend family events, but accounts, purchases and posting are for adults only."
- **Under-18 message:** "Sorry, you can't create a Common account yet. The Common is for people aged 18 and over. You're welcome to come back when you turn 18."
- **Checkout confirmation:** "I confirm I am 18 or over and am buying as an adult. If I am buying tickets for children, I am their parent or guardian and am responsible for them at the event."
- **Terms of Use clause:** "You must be 18 or over to use The Common. By creating an account you confirm that you are. We do not knowingly collect information from anyone under 18. If we learn that an account belongs to someone under 18, we will suspend it and delete their personal information, except where the law requires us to keep it. Businesses and event hosts must not target content, offers or events at under-18s as account holders."

Data model

Table	Key fields	Purpose
age_declarations	id, user_id, username (snapshot at the time), declared_18_plus, declaration_type (signup, existing_account, redeclaration, purchase), declared_at, terms_version, privacy_notice_version, order_id (for purchases), ip_address, user_agent, status, reviewed_by, reviewed_at, outcome_note	One row for every declaration made; append-only apart from status and review fields

Table	Key fields	Purpose
age_block_events	id, device_hash, blocked_at, expires_at	Short-lived record that stops an immediate retry; no personal data and deleted after expiry

Status values: Declared, Flagged (suspected under 18), Confirmed adult, Account removed. The date of birth is never stored, logged or exported.

Admin view: age declarations

- **Search by:** username, user ID and date range (declared from and to). Optional filters: status, declaration type, role.
- **List columns:** declared date and time, username, user ID, role, declaration type, terms version, status.
- **Detail:** all declarations for that user in date order, linked orders for purchase declarations, reports of "may belong to a child", the review history and the audit entries.
- **Actions:** Flag as suspected under 18 (admin, suspends the account), Confirm adult (admin, with reason), Remove account (super user only, with reason).
- **Export:** admin and super user can export the filtered list to CSV (username, user ID, role, declaration type, declared_at, terms version, status, outcome). The export is logged.

Endpoints

Method and path	Roles	Purpose
POST /auth/age-declaration	New user	Body: dateOfBirth, acceptedTerms, termsVersion. Returns allowed or blocked. The date of birth is discarded after the age check
POST /auth/age-declaration/renew	Signed-in user	Existing account declaration, or after a Terms change
POST /checkout/age-confirmation	Buyer	Confirms the purchase declaration and links it to the order
GET /admin/age-declarations	Admin, super user	Params: username, userId, from, to, status, type, role, page

Method and path	Roles	Purpose
GET /admin/age-declarations/{id}	Admin, super user	Detail and history (the view is logged)
POST /admin/age-declarations/{id}/flag	Admin, super user	Suspects under 18, suspends the account, reason required
POST /admin/age-declarations/{id}/confirm-adult	Admin, super user	Reinstates the account, reason required
POST /admin/age-declarations/{id}/remove-account	Super user	Removes the account and personal data, reason required
POST /admin/age-declarations/export	Admin, super user	Returns a job ID for the CSV; the export is logged

Audit events added

AGE_DECLARED, AGE_BLOCKED (device hash only, no user ID because no account exists), AGE_REDECLARED, AGE_PURCHASE_CONFIRMED, AGE_RECORD_VIEWED, AGE_FLAGGED, AGE_CONFIRMED_ADULT, AGE_ACCOUNT_REMOVED, AGE_EXPORTED.

Retention (to be confirmed with legal)

- Age declaration records: for the life of the account, then a fixed period matching the audit log.
- Block events: deleted when they expire.
- Removed accounts: personal data deleted. Keep only the minimal audit entry that the declaration, flag and removal occurred.

Acceptance criteria

- [ ] Sign-up cannot continue without a date of birth and a ticked declaration.
- [ ] A date of birth under 18 creates no account, saves no entered details, and blocks retry for 24 hours.
- [ ] The date of birth never appears in the database, logs, audit entries or exports.
- [ ] Existing accounts see the declaration screen before any other action on next sign-in.
- [ ] A ticket or marketplace purchase cannot complete without the purchase confirmation.
- [ ] An admin can search declarations by username, user ID and date range, and combine them.
- [ ] Flagging suspends the account immediately; only the super user can remove an account.
- [ ] Every declaration, view, flag, confirmation, removal and export creates an audit entry.

- [ ] The CSV export respects the current filters and opens in Excel.